

Section 32: The Security Threat Landscape

Layer: All | Reference: Odom Vol2 Ch3: Security Architectures (threat concepts) | *Original study notes — CCNA 200-301*

Before configuring specific defenses like ACLs or port security, the CCNA exam expects familiarity with the categories of threats those defenses exist to counter - both for direct test questions and for understanding WHY each mitigation matters.

Key Concepts

- Reconnaissance attacks gather information about a target network before a real attack (e.g., port scanning, ping sweeps) - often the first phase of a broader attack
- Access attacks attempt to gain unauthorized entry to systems or data, including password attacks, exploitation of trust relationships, and port redirection
- DoS (Denial of Service) attacks aim to make a resource unavailable, typically by overwhelming it with traffic or exploiting a resource-exhaustion bug; DDoS (Distributed DoS) uses many compromised hosts simultaneously
- Social engineering manipulates people rather than systems directly - phishing, pretexting, and tailgating are common examples that bypass technical controls entirely
- Malware categories: viruses (require a host file and user action to spread), worms (self-propagating, no user action needed), trojans (disguised as legitimate software)
- Man-in-the-Middle (MITM) attacks intercept communication between two parties, often via ARP spoofing/poisoning on a local network
- Spoofing attacks falsify a source identifier (IP spoofing, MAC spoofing, ARP spoofing) to impersonate a trusted entity
- The CIA triad frames security goals: Confidentiality (data only accessible to authorized parties), Integrity (data not altered improperly), Availability (systems/data accessible when needed) - most attacks target one or more of these three pillars
- Defense-in-depth means layering multiple independent security controls so a single failure doesn't compromise the whole system - a core philosophy behind combining ACLs, port security, DHCP snooping, and DAI together rather than relying on just one

Command Reference

Command	Purpose
<code>show ip arp inspection</code>	Verify DAI is actively blocking spoofed ARP traffic (related mitigation)
<code>show port-security</code>	Verify port security is mitigating MAC-flooding style access attacks
<code>show access-lists</code>	Verify ACL-based mitigations are matching expected traffic

Configuration Walkthrough

This section is conceptual; see Sections 27/28/33 for the matching configuration.

! No direct configuration commands for this section.

Worked Scenario

Q: An attacker floods a switch's CAM table with thousands of fake MAC addresses. What category of attack is this, and what specifically does it threaten?

This is a MAC flooding attack, a form of access/availability attack. Once the CAM table fills up, the switch can no longer learn legitimate MAC-to-port mappings and may fail open by flooding ALL traffic to ALL ports like a hub - turning a switched network into one the attacker can passively eavesdrop on. Port security (limiting MACs per port) is the direct, exam-relevant mitigation.

Common Mistakes / Gotchas

- Treating 'DoS' and 'DDoS' as interchangeable - the distinction (single source vs distributed/many sources) is tested directly
- Forgetting that reconnaissance often precedes a real attack and isn't itself destructive, but is still a meaningful warning sign
- Underestimating social engineering as 'not a real network attack' - it's explicitly part of the exam's threat landscape

Exam Tips

- ★ Memorize the CIA triad and be ready to map an attack scenario to which pillar it threatens
- ★ Know the malware distinctions: virus needs a host file + user action, worm self-propagates, trojan disguises itself
- ★ This section is the 'why' behind Section 27 Port Security, Section 28 ACLs, and Section 33 Device Security - study them together